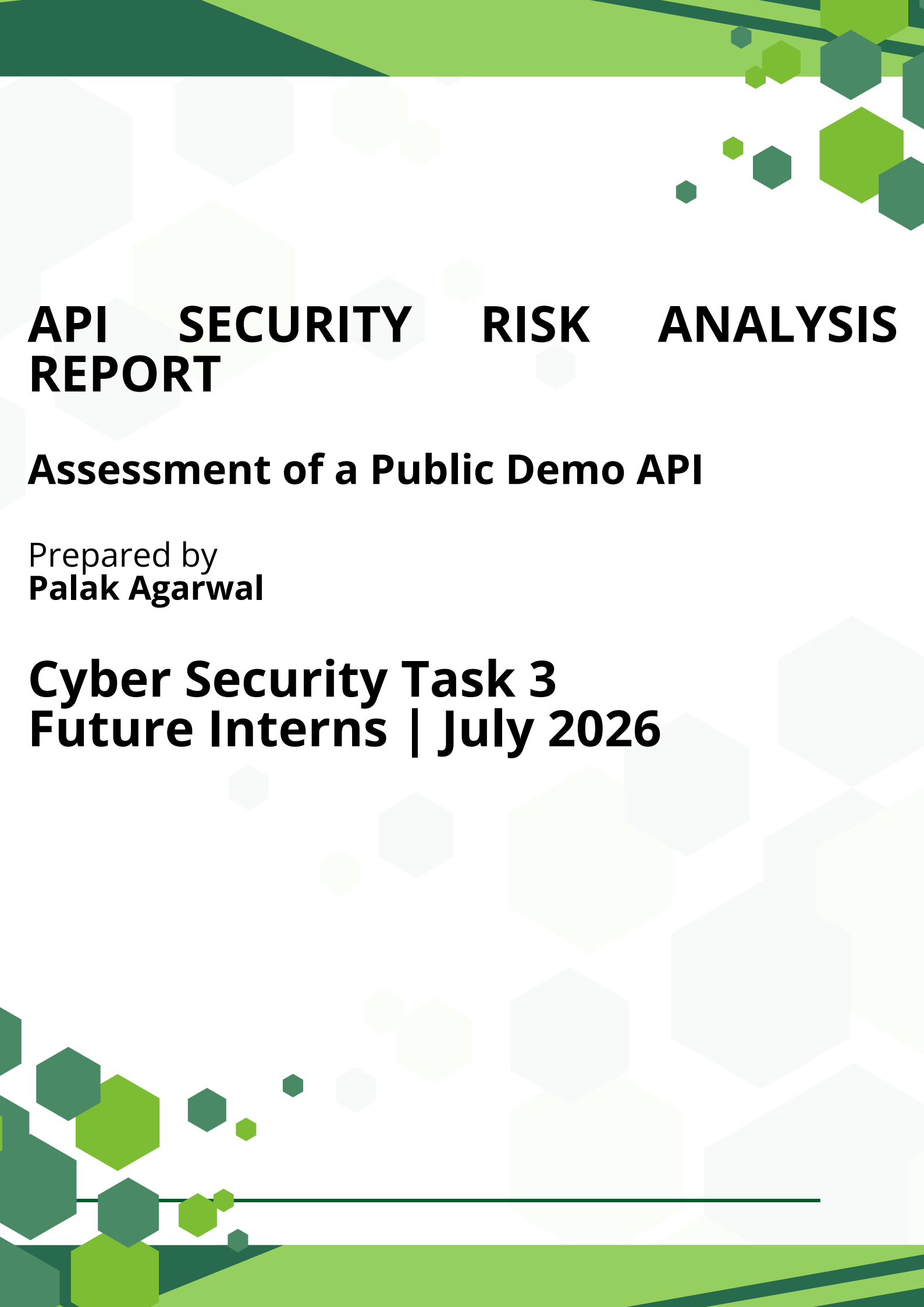




API SECURITY RISK ANALYSIS REPORT

Assessment of a Public Demo API

Prepared by
Palak Agarwal

**Cyber Security Task 3
Future Interns | July 2026**

API OVERVIEW & SCOPE

Section 1: API Selected

API Selected: JSONPlaceholder

Base URL: <https://jsonplaceholder.typicode.com>

Type: Public demo REST API

Purpose: Safe learning and testing environment

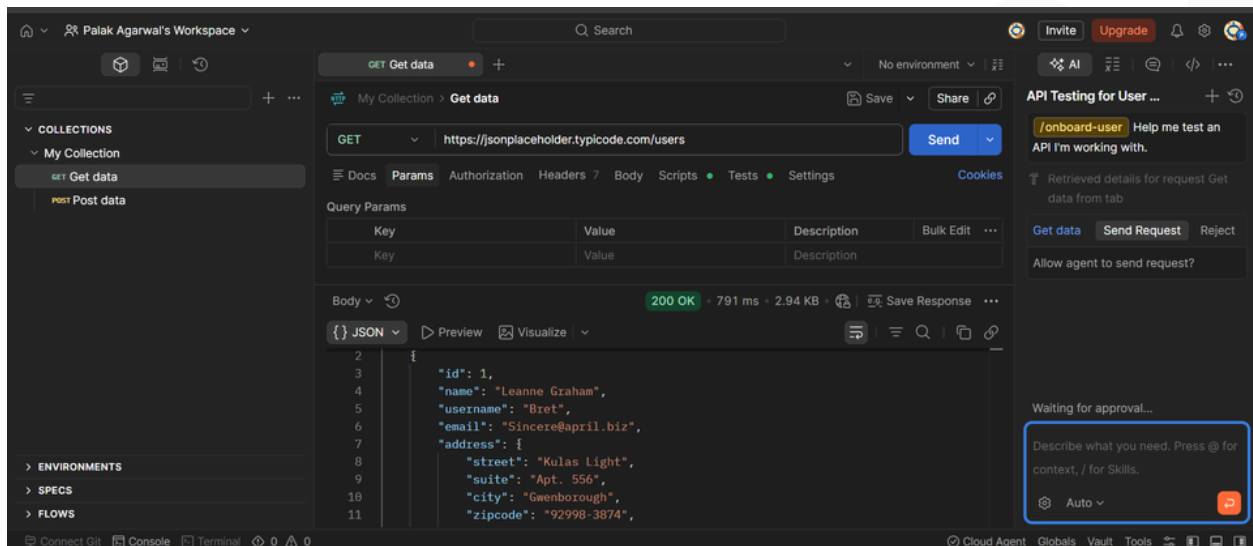
Section 2: Endpoints Reviewed

- GET /users
- GET /users/1
- GET /posts?userId=1

Section 3: Scope & Ethics

This assessment used only read-only GET requests on a public demo API.

No exploitation, unauthorized access attempts, data modification, or load testing was performed.



Tools Used: Postman | Browser DevTools | API Documentation

API TESTING EVIDENCE

Test 1: Retrieve User List

Request: GET /users

Result: 200 OK

Observation: The API returned a list of user records in JSON format. No authentication token was required because this is a public demo API.

Test 2: Retrieve Individual User

Request: GET /users/1

Result: 200 OK

Observation: The endpoint returned details for a single user, including name, username, email and address fields.

Test 3: Retrieve User Posts

Request: GET /posts?userId=1

Result: 200 OK

Observation: The API returned posts associated with User ID 1. The query parameter was accepted correctly.

All requests were read-only GET requests performed on a public testing API.

SECURITY FINDINGS & RISK ASSESSMENT

Finding	Severity	Business Impact	Recommendation
Publicly accessible	Low	Demo API data can be viewed	Use authentication for
User information exposed in	Medium	Email and address details could be	Return only necessary fields
No visible rate limiting	Medium	Repeated requests could	Apply rate limiting,
No authentication required for	Low	Suitable for a demo API, but	Require API keys, tokens, or OAuth

Note: These findings are based on a public demo API and are presented for educational risk-analysis purposes only.

BUSINESS IMPACT

- Data Privacy Risk

If personal information is exposed through an API, it can affect user privacy and trust.

- Reputation Risk

A security incident can reduce customer confidence in the company.

- Operational Risk

Excessive automated requests may slow down the API or affect service availability.

- Compliance Risk

Poor protection of personal data may create legal or regulatory concerns for a real business.

Although JSONPlaceholder is a safe public demo API, the same weaknesses in a production API could create meaningful business and security risks.

RECOMMENDATIONS & REMEDIATION PLAN

1. Implement Authentication

Use API keys, tokens, or OAuth to protect sensitive endpoints and verify user access.

2. Apply Authorization Controls

Ensure users can access only the data and actions permitted for their role.

3. Minimize Data Exposure

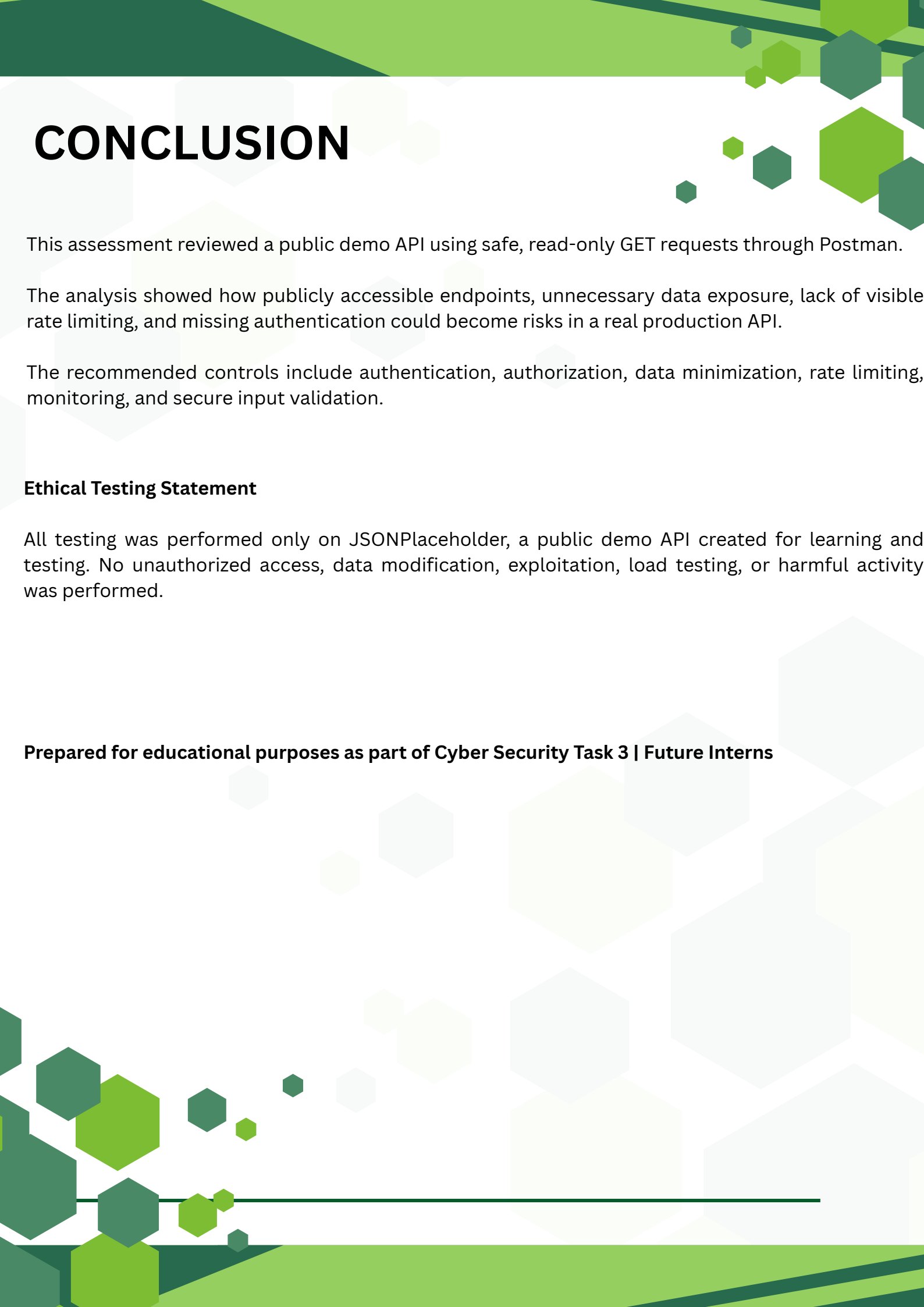
Return only the fields required by the application and avoid exposing unnecessary personal information.

4. Add Rate Limiting and Monitoring

Limit repeated requests and monitor unusual API activity to reduce abuse and availability risks.

5. Validate Inputs and Handle Errors Securely

Validate request data and avoid returning detailed error messages that may reveal internal system information.



CONCLUSION

This assessment reviewed a public demo API using safe, read-only GET requests through Postman.

The analysis showed how publicly accessible endpoints, unnecessary data exposure, lack of visible rate limiting, and missing authentication could become risks in a real production API.

The recommended controls include authentication, authorization, data minimization, rate limiting, monitoring, and secure input validation.

Ethical Testing Statement

All testing was performed only on JSONPlaceholder, a public demo API created for learning and testing. No unauthorized access, data modification, exploitation, load testing, or harmful activity was performed.

Prepared for educational purposes as part of Cyber Security Task 3 | Future Interns
